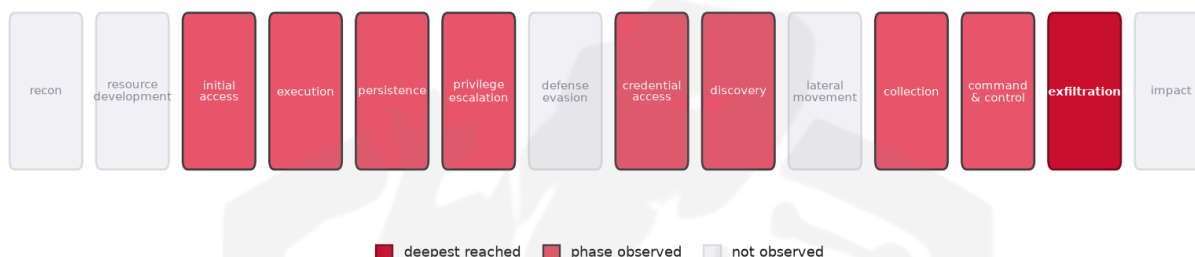


THREAT REPORT: MIRAGE KITTEN TARGETS AVIATION AND FINTECH SECTORS

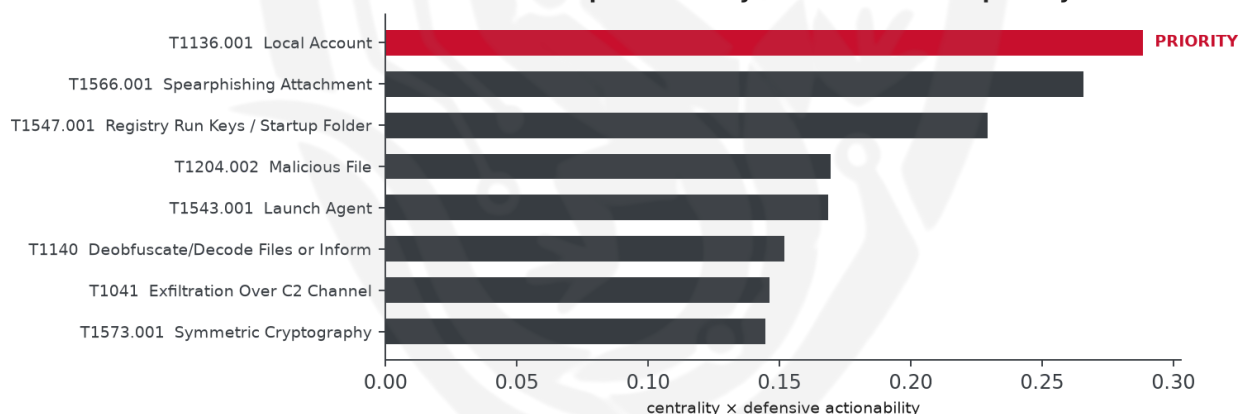
Visual Summary

Kill-Chain Reach — Critical (deepest phase reached: exfiltration)



How far down the attack chain this campaign reached; deepest phase in crimson.

Defensive Chokepoint — why this control is the priority



The control that most disrupts the attack (priority in crimson).

Summary

Mirage Kitten is conducting a campaign that deploys the NodeRabbit, PollCat, Retrograde and MiniFast malware families. The activity is aimed at organizations in the finance and aerospace sectors across the Middle East and Africa. Because the group creates new local and domain accounts as part of its operation, defenders should alert on account-creation events (Event ID 4720/4728) and enforce an approval workflow for provisioning.

Threat Overview

The source attributes this activity to Mirage Kitten. The campaign leverages a suite of malware—NodeRabbit, PollCat, Retrograde and MiniFast—without a known exploited CVE (the central CVE is listed

as data insufficient). Victims are primarily financial services and aerospace entities operating in the Middle East and Africa.

Attack Chain and Priority Control

The observed sequence begins with spearphishing attachments that deliver malicious files, which are then executed via JavaScript and launch agents or registry run-key persistence. The malware establishes scheduled tasks, creates local accounts, and performs keylogging, system and process discovery, and local data staging. Collected data is encrypted with symmetric cryptography, obfuscated, and exfiltrated over web-protocol C2 channels, sometimes using an internal proxy.

The chokepoint technique identified by the source is **T1136.001 Local Account**. **Priority control:** *Alert on new local/domain account creation (Event ID 4720/4728); enforce approval workflow for account provisioning.*

Infrastructure and Corroboration

No hosting-provider or ASN information was observed for the malicious infrastructure. Abuse.ch corroborates the presence of the MiniFast malware family in this activity. No high-confidence AbuseIPDB flags were associated with the indicators.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1053.005 Scheduled Task
- T1056.001 Keylogging
- T1059.007 JavaScript
- T1074.001 Local Data Staging
- T1204.002 Malicious File
- T1573.001 Symmetric Cryptography
- T1566.001 Spearphishing Attachment
- T1082 System Information Discovery
- T1005 Data from Local System
- T1140 Deobfuscate/Decode Files or Information
- T1136.001 Local Account
- T1083 File and Directory Discovery
- T1057 Process Discovery
- T1041 Exfiltration Over C2 Channel
- T1547.001 Registry Run Keys / Startup Folder
- T1027 Obfuscated Files or Information
- T1543.001 Launch Agent

- T1071.001 Web Protocols
- T1105 Ingress Tool Transfer
- T1090.001 Internal Proxy

Analytical Scores

- Priority technique (graph chokepoint): T1136.001 Local Account (centrality 0.3037).
- Operational risk: Critical (score 0.968, reaches exfiltration).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.5798; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
Higaisa	0.5798
APT39	0.5208
Inception	0.5154
Darkhotel	0.5154
Molerats	0.495

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.
- Malware families corroborated by abuse.ch: MiniFast.
- Note: enrichment raises the severity signal (an IOC at or above 80% AbuseIPDB confidence, or a confirmed malware-family hit). This is context, not a change to the source assessment.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator	Context
Domain	msmanagementgrp[.]com	
Domain	sahi-finance[.]com	

Type	Indicator	Context
Domain	healthcomfsdpower[.]com	
Domain	visitfinancedentists[.]com	
Domain	optimumhealthcredit[.]com	
Domain	lifespotify[.]com	
Domain	msmanagementgrpmedia[.]com	
Domain	healthful-hub[.]com	
Domain	neumedicahealthcare[.]com	
Domain	healthfullyrecipes[.]com	
Domain	refreshhealthandwellness[.]com	
Domain	healthvitalitycare[.]com	
Domain	aceofspadesmanagement[.]com	
Domain	glmediaagency[.]com	
Domain	digimediaskill[.]com	
Domain	healthyweightplan[.]com	
Domain	mens-health-online[.]com	
URL	hxxps://lifespotify[.]com/api/users/b879746e-fed9-4211-a6da-4d8223681267/otp/validate	
URL	hxxps://visitfinancedentists[.]com	
URL	hxxps://healthcomfsdpower[.]com	
URL	hxxps://sahi-finance[.]com	
Hash	810f8e3b88eb05f710c09552941d6f56	MiniFast
Hash	da11679653ef33952c3dc8d8850e43d7b8ac884a	
Hash	0db36a04d304ad96f9e6f97b531934594cd95a5cea9ff2c9af249201089dc864	
Hash	1ea83e4e4592b01e4acab63eb867bee5	MiniFast
Hash	cbaaf0900a13f28e380f49adecec932c	MiniFast
Hash	366515822d5ac1cc500711ef57a2e32e	MiniFast

Type	Indicator	Context
Hash	cf449f1992c2819e62ac44a0b06ac2e7	MiniFast
Hash	e95a4366686e3f786ea3c056fab5b0da	MiniFast
Hash	de5af16a3757ef700b01dc34d67079ae	MiniFast
Hash	be086789568441d0d7e4679aee51f566	MiniFast
Hash	e259c5edf158aac4cfe14f77ddd0b196	MiniFast
Hash	291ac3abe73c5158e59a437b75d5f0aa	MiniFast
Hash	0962f56d7ec69f4f2a0162dcbe22116b	MiniFast
Hash	795e053a990a1569ffdc57f48f6d085	MiniFast
Hash	f0c8db403231d478f67df0355328c58384027677	
Hash	307ce2448211a5f5d122643f2a739aff33ede72c1858518c8de098f3148bbd00	

Reputation by AbuseIPDB · malware attribution by abuse.ch · Geo/ASN data by IP2Location LITE.

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1136.001 Local Account (persistence)
- **Observed here:** T1136.001 Local Account was the only persistence technique observed in this campaign, so the pivot is projected from cross-actor behaviour.
- **Projected pivot:** T1098 Account Manipulation (persistence)
- **Basis:** of the 13+ groups that use Local Account, this pairing runs 5.6x above base rate, a disproportionately-coupled move rather than the obvious one.

If the creation of a new local account is blocked, the adversary could pivot by targeting an existing privileged account and using T1098 Account Manipulation to add themselves to high-privilege groups or inject new credentials, thereby achieving elevation without needing a fresh account. Defenders should alert on privilege/group changes and credential additions to accounts (Event ID 4738/4670); review conditional-access changes.

Also plausible (same tactic): T1505 Server Software Component (n=12, lift 2.9), T1133 External Remote Services (n=10, lift 2.8)

Detection and hardening for the pivot (T1098 Account Manipulation)

- **Telemetry:** Windows Security (account management); Azure AD audit logs

- **Detect:**
 - Security 4728/4732/4756 (added to security-enabled groups), 4738 (account changed), 4670 (permissions changed)
 - New credentials/keys added to accounts or app registrations in the IdP
 - MFA method added or reset outside a normal workflow
- **Harden:**
 - Alert on privileged-group changes; approval workflow for role grants
 - Monitor and restrict service-principal credential additions
- **MITRE:** M1032 Multi-factor Authentication, M1026 Privileged Account Management, M1018 User Account Management · DS0002 User Account, DS0026 Active Directory

